



AS400 Security Standard

Revision Number: 1.4

Date Effective: 01 September 2012

Date Last Updated: 10 June 2016

Date Last Reviewed: 10 June 2016

Prepared by: IT Risk Management and Security

Purpose

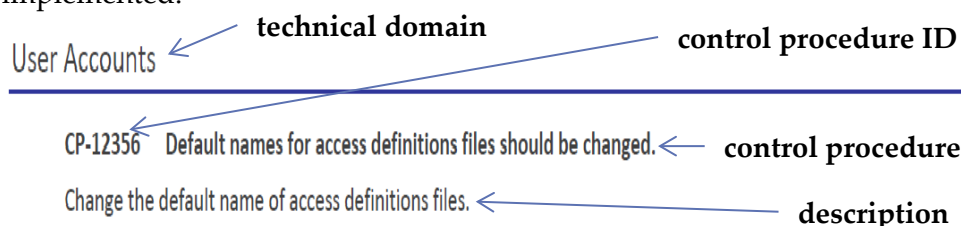
Establish a minimum set of technical measures necessary for the secure installation, setup, configuration, and operation of AS400.

Scope

These standards apply to all instances of AS400 owned by or operated on behalf of Merck. Where equivalent or superior technical measures exist to secure the technology, those measures may be applied to satisfy the control procedures defined below.

Structure and Layout

The standards are grouped by **technical domains**. Each technical domain includes one or more **control procedures** uniquely identified by its **control procedure ID**. The control procedure ID allows the traceability of the standard to Archer, the software application used by Merck ITRMS for IT Governance, Risk, and Compliance. Underneath the control procedure is a **description** that provides further context on how the standard can be implemented.



What are technical security standards?

...

Technical security standards are settings and procedures necessary for securing a particular technology platform. With the use of Archer, Merck ITRMS is able to collaborate with key technology platforms in determining a set of technical standards in line with best practices while recognizing the constraints and unique characteristics of our operating environment.

...

AS 400

Technical Security Standards v1.4

Auditing, Logging and Monitoring

CP-125547 Failed login events should be audited.

Monitor message queues on a daily basis and accounts that are being locked out from intruder detection and recognize if a pattern of user accounts is being locked out. Also review the audit journal for unsuccessful attempts. (Authorization failures cause AF type entries in the audit journal.) When properly configured, the AS/400 will log invalid attempts and lock accounts that have exceeded the allocated unsuccessful logins. This can often be the first sign of an intruder trying to break into the system. Additionally, with every invalid login attempt a message is sent to the QSYSOPR message queue (and QSYSMSG message queue if it exists in library QSYS) to notify the security officer of a possible intrusion. If a QSYSMSG message queue is created in the QSYS library, messages about critical system events are sent to that message queue as well as to QSYSOPR.

Groups

CP-125540 Appropriate naming conventions should be used. The profile name should clearly indicate it is a group profile.

Use consistent naming conventions for group profiles throughout the organization.

CP-125548 Group profiles should not be able to login to the system.

Assign a password of *NONE to all group profiles

Maintenance and Operations

CP-125536 All programs that adopt authority should be known by the administrator and checked periodically for changes.

Review programs that adopt authority by using the following command: DSPPGMADP USRPRF(user-profile-name) + OUTPUT(PRINT)

CP-125591 The system key should be set to the "normal" or "automatic" position, removed from the system and kept in a secure location.

Set the physical system key to the ""normal"" or ""automatic"" position. Remove the key from the system and keep in a secure location.

Password Management

CP-125534 A minimum password length should be enforced in accordance with corporate standards.

Enable the Password Minimum Length (QPWDMINLEN) system setting. Recommended guidelines state a value of 8 or greater.

AS 400

Technical Security Standards v1.4

CP-125551 Passwords should be changed regularly in accordance with applicable corporate standards.

Set the QPWDEXPITV parameter in accordance with corporate standards. Potential settings for QPWDEXPITV: - *NOMAX: The system allows an unlimited number of days. - "1"- "366": A value from "1" to "366" can be specified.

CP-125552 Passwords should be changed regularly in accordance with applicable corporate standards.

The minimum password lifetime should be set according to corporate password policy. Users should be given adequate warning of the impending change requirement. When passwords expire, users should be required to change their password immediately. The system value QPWDEXPITV determines the frequency with which passwords must be changed on the system. A value of *NOMAX indicates that there is no forced change. Values from 1 to 366 specify the number of days after which passwords must be changed

CP-125564 The "Check password based on rules in a program" parameter (QPWDVLDPGM) should be properly configured.

Set the QPWDVLDPGM parameter. Recommended Value: - *NONE Potential settings for QPWDVLDPGM: - *NONE: No program is used. - *Program-name: Specify the name of the validation program.

CP-125569 The "Enforces different characters when passwords are changed" parameter (QPWDPOSDIF) should be properly configured.

Set the QPWDPOSDIF parameter. Recommended value: - 1 if QRWPOSDIF is not enforced; 0 otherwise. Potential settings for QPWDPOSDIF: - "0": The same characters can be used in a position corresponding to the same position in the previous password. - "1": The same character cannot be used in a position corresponding to the same position in the previous password.

CP-125573 The "Limit adjacent characters" parameter (QPWDLMTAJC) should be properly configured.

Set the QPWDLMTAJC parameter. Recommended value:- 1 Potential settings for QPWDLMTAJC: - "0": Adjacent characters are allowed in passwords. - "1": Adjacent characters are not allowed in passwords.

CP-125576 The "Limit repeated characters" parameter (QPWDLMTREP) should be properly configured.

Set the QPWDLMTREP parameter to limit repeating characters in a password. Recommended value: - 2 Potential settings for QPWDLMTREP: - "0": Characters can be repeated more than once. - "1": Characters cannot be repeated. - "2": The same character cannot be used consecutively in a password

CP-125579 The "Password Maximum length" parameter (QPWDMAXLEN) should be properly configured

Set the QPWDMAXLEN parameter in accordance with corporate standards. If no corporate standard is applicable, limit the length of the password to a reasonable length to limit the possibility of users creating long passwords where they can not remember the values.

AS 400

Technical Security Standards v1.4

CP-125580 The "Passwords required to be different?" parameter (QPWDRQDDIF) should be properly configured.

Set the QPWDRQDDIF parameter to disallow recycling of passwords. Recommended value: - A value between 5 - 7. Potential settings for QPWDRQDDIF: - "0": Password can be the same as previous ones. - "1": Password must not be the same as the previous 32 passwords. - "2": Password must not be the same as the previous 24 passwords. - "3": Password must not be the same as the previous 18 passwords. - "4": Password must not be the same as the previous 12 passwords. - "5": Password must not be the same as the previous 10 passwords. - "6": Password must not be the same as the previous 8 passwords. - "7": Password must not be the same as the previous 6 passwords. - "8": Password must not be the same as the previous 4 passwords

CP-125582 The "Require a number in the password" parameter (QPWDRQDDGT) should be properly configured.

Set the QPWDRQDDGT parameter. Recommended value:- 1Potential settings for QPWDRQDDGT: - "0": Digits are not required in new passwords. - "1": One or more digits are required in new passwords.

Passwords

CP-125585 The account lockout feature, disabling an account after a number of failed log in attempts, should be enabled and the related parameters should be set in accordance with corporate security standards and guidelines.

Enable the Maximum Signon Attempts (QMAXSIGN) system setting for all user profiles. General recommended guidelines state locking out the account after 3 - 5 bad logon attempts

CP-125595 Users should be required to have unique passwords.

Enable the Require Difference in Passwords (QPWDRQDDIF) system setting. Recommended guidelines state a value of 1.

Physical Access to Computer Centers

CP-125590 The room where the servers are located should be physically secure.

The servers must be located in a secure area and access restricted to authorized personnel only.

Sensitive Utility Controls

CP-125587 The default IBM passwords for dedicated service tools (DST) should be changed. DST profiles do not appear on a DSPAUTUSR list.

Verify that the passwords are changed by starting DST and attempting to execute the default values.

System Configuration

CP-125545 Device configuration should be controlled.

Set the QAUTOCFG parameter. QAUTOCFG (Automatic Device Configuration) this system value specifies whether devices that are added to the system are configured automatically. Recommended value is:- 0 Potential values for QAUTOCFG are: - 0 - Automatic configuration is off. All local controllers or devices have to be manually configured - 1 - Automatic configuration is on. The system automatically configures any new local controllers or devices that are added to the system. The operator receives a message that indicates the changes to the system's configuration.

CP-125559 The "Action when maximum sign-on attempts are exceeded" parameter (QMAXSGNACN) should be properly configured.

Set the QMAXSGNACN parameter. Recommended value: - 3 Potential settings for QMAXSGNACN: - 3 - Disable both the user profile and device. - 2 - Disable the user profile only. - 1 - Disable the device only. - 0 - Users with *ALLOBJ or *SERVICE special authority can sign on at any display station for which they have *CHANGE authority. They can receive *CHANGE authority through private or public authority or because they have *ALLOBJ special authority. Note: The system disables a device by varying it off. The device is disabled only if the sign-on attempts that are not valid are consecutive on the same device. One valid sign-on resets the count of incorrect sign-on attempts for the device. The system disables a user profile by changing the Status parameter to *DISABLED. The user profile is disabled when the number of incorrect sign-on attempts for the user reaches the value in the QMAXSIGN system value, regardless of whether the incorrect sign-on attempts were from the same or different devices. One valid sign-on resets the count of incorrect sign-on attempts in the user profile.

CP-125560 The "Allow object restore option" parameter (QALWOBJRST) should be properly configured.

Set the QALWOBJRST parameter. Recommended value: - For normal operations, consider setting this value to *NONE. Remember to change it to *ALL before performing the activities listed previously. If you regularly restore programs and applications to your system, you may need to set the QALWOBJRST system value to *ALWPGMADP. Potential settings for QALWOBJRST: - *ALL - Any object may be restored to your system by a user with the proper authority. - *NONE - Security-sensitive objects, such as system state programs or programs that adopt authority, may not be restored to the system. - *ALWSYSST - System state objects may be restored to the system. - *ALWPGMADP - Objects that adopt authority may be restored to the system. - *ALWPTF - System and inherit state objects, objects that adopt authority, objects that have the S_ISUID(set-user-ID) attribute enabled, and objects that have S_ISGID (set-group-ID) attribute enabled can be restored to the system during PTF install. - *ALWSETUID - Allow restore of files that have the S_ISUID (set-user-ID) attribute enabled. - *ALWSETGID - Allow restore of files that have the S_ISGID (set-group-ID) attribute enabled.

CP-125561 The "Auditing control" parameter (QAUDCTL) should be properly configured.

Set the QAUDCTL parameter. The QAUDCTL system value determines whether auditing is performed. It functions like an on and off switch for the following: - The QAUDLVL system value - The auditing defined for objects using the Change Object Auditing (CHGOBJAUD) and Change DLO Auditing (CHGDLOAUD) Commands - The auditing defined for users using the Change User Audit (CHGUSRAUD) command Recommended value: - *AUDLVL You can specify more than one value for the QAUDCTL system value, unless you specify *NONE. Potential settings: - *NONE No auditing of user actions and no auditing of objects is performed. - *OBJAUD Auditing is performed for objects that have been selected using the CHGOBJAUD and CHGDLOAUD commands. - *AUDLVL Auditing is performed for any functions selected on the QAUDLVL system value and on the AUDLVL parameter of individual user profiles. The audit level for a user is specified using the Change User Audit (CHGUSRAUD) command. - *NOQTEMP Auditing is not performed for most actions if the object is in QTEMP library.

CP-125562 The "Auditing end action" parameter (QAUDENDACN) should be properly configured.

Set the QAUDENDACN parameter. Recommended value: - *NOTIFY Potential settings for QAUDENDACN: - *NOTIFY Message CPI2283 is sent to the QSYSOPR message queue and the QSYSMSG message queue (if it exists) every hour until auditing is successfully restarted. The system value QAUDCTL is set to *NONE to prevent the system from attempting to write additional audit journal entries. Processing on the system continues. If an IPL is performed before auditing is restarted, message CPI2284 is sent to the QSYSOPR and QSYSMSG message queues during the IPL. - *PWRDWNSYS If the system is unable to write an audit journal entry, the system powers down immediately. The system unit displays system reference code (SRC) B900 3D10. When the system is powered on again, it is in a restricted state. This means the controlling subsystem is in a restricted state, no other subsystems are active, and sign-on is allowed only at the console. The QAUDCTL system value is set to - *NONE. The user who signs on the console to complete the IPL must have *ALLOBJ and *AUDIT special authority.

CP-125565 The "Create default auditing" parameter (QCRTOBJAUD) should be properly configured.

Set the QCRTOBJAUD parameter. Recommended value: - *CHANGE Potential settings for QCRTOBJAUD: - *NONE - No auditing is done for the object. - *USRPRF - Auditing of the object is based on the value in the profile of the user accessing the object. - *CHANGE - An audit record is written whenever the object is changed. - *ALL - An audit record is written for any action that affects the contents of the object. An audit record is also written if an object's contents change.

CP-125571 The "Inactive job time-out interval" parameter (QINACTIV) should be properly configured.

Set the QINACTIV parameter. Recommended value: - 30 minutes Potential settings for QINACTIV: - *NONE - The system does not check for inactive jobs. Interval-in-minutes - Specify a value of 5 through 300. When a job has been inactive for that number of minutes, the system takes the action specified in QINACTMSGQ.

CP-125575 The "Limit device sessions" parameter (QLMTDEVSSN) should be properly configured.

Set the QLMTDEVSSN parameter. Recommended value: - 1 Potential settings for QLMTDEVSSN: - 0 - The system allows an unlimited number of sign-on sessions. - 1 - Users are limited to one device session. Note: Limiting device sessions can also be specified in individual user profiles.

CP-125578 The "Maximum sign-on attempts" parameter (QMAXSIGN) should be properly configured.

Set the QMAXSIGN parameter. Recommended value: - 3 - 5 Potential settings for QMAXSIGN: - *NOMAX - The system allows an unlimited number of incorrect sign-on attempts. This gives a potential intruder unlimited opportunities to guess a valid user ID and password combination. Limit - Specify a value from 1 through 25. The recommended number of sign-on attempts is three. Usually three attempts are enough to correct typing errors but low enough to help prevent unauthorized access.

CP-125588 The QLMTDEVSSN system setting should be set according to the corporate security policy

Set the QLMTDEVSSN system setting in accordance with corporate standards. Industry standard is to allow only one session per user. The system value QLMTDEVSSN (Limit Device Sessions) defines whether users can sign on to more than one terminal at the same time. Possible values are: - 1 - Users cannot have concurrent logins. - 0 - Users are allowed concurrent logins.

System Value Controls

AS 400

Technical Security Standards v1.4

CP-125563 The "Auditing level" parameter (QAUDLVL) should be properly configured.

Set the QAUDLVL parameter. Recommended values: - *AUTFAIL- *CREATE- *DELETE- *PGMADP- *SECURITY- *SERVICE Potential settings for QAUDLVL: - *NONE - No events controlled by the QAUDLVL system value are logged. Events are logged for individual users based on the AUDLVL values of user profiles. - *AUTFAIL - Authority failure events are logged. - *CREATE - Object create operations are logged. - *DELETE - Object delete operations are logged. - *JOBDDTA - Actions that affect a job are logged. - *NETCMN - Violation detected by APPN Filter support is logged. - *OBJMGT - Object move and rename operations are logged. - *OFCSRVR - Changes to the system distribution directory and office mail actions are logged. - *OPTICAL - Use of Optical Volumes is logged. - *PGMADP - Obtaining authority from a program that adopts authority is logged. - *PGMFALL - System integrity violations are logged. - *PRDTTA - Printing a spooled file, sending output directly to a printer, and sending output to a remote printer are logged. - *SAVRST - Restore operations are logged. - *SECURITY - Security-related functions are logged. - *SERVICE - Using service tools is logged. - *SPLFDDTA - Actions performed on spooled files are logged. - *SYSMGT - Use of system management functions is logged.

CP-125567 The "DDM Request access network attribute" (DDMACC) should be properly configured.

Set the DDMACC parameter. DDMACC (DDM Request Access Network Attribute): This network attribute determines how the system processes requests from other systems to access data using the distributed data management (DDM) or the distributed relational database function. Recommended value is: - *OBJAUT Potential values for DDMACC are: - *REJECT - The system does not allow any DDM or DRDA requests from remote systems. *REJECT does not prevent this system from functioning as the requester system and sending requests to other server systems. - *OBJAUT - Remote requests are controlled by the object authority on the system. Qualified- program- name - This user-written exit program is called after normal object authority has been verified. The exit program is called only for DDM files, not for distributed relational database functions. The exit program is passed a parameter list, built by the remote system, that identifies the local system user and the request. The program evaluates the request and sends a return code, granting or denying the requested access.

CP-125589 The Retain Server Security parameter (QRETSVRSEC) should be properly configured.

Recommended value: - 0 The following summarizes the potential settings for QRETSVRSEC: - 0 - Server security data is not retained. - 1 - Server security data is retained. Note: If you change the value from 1 to 0, the system removes the authentication information from the system. If you have a large number of user profiles or validation lists on your system when you make this change, the CHGSYSVAL command may run for an extensive period of time. The encrypted data field of a validation list entry is typically used to store authentication information. Applications specify whether to store the encrypted data in a decryptable or non-decryptable form. If the applications choose a decryptable form and the QRETSVRSEC value is changed from 1 to 0, the encrypted data field information is removed from the entry. If the encrypted data field of a validation list entry is stored in a non-decryptable form, it is not affected by the QRETSVRSEC system value.

AS 400

Technical Security Standards v1.4

CP-125592 The "Client Request access network attribute" (PCSACC) should be properly configured.

Set the PCSACC parameter. PCSACC (Client Request Access Network Attribute): this network attribute determines how the Client Access license program processes requests from attached personal computers to access objects. The PCSACC network attribute controls whether personal computer jobs can access objects on the AS/400 system, not whether the personal computer can use workstation emulation. Note: PCSACC network attribute controls only the DOS and OS/2 clients. This attribute has no effect on any other Client Access clients. Recommended value is: - *REJECT Potential values for PCSACC are: - *REJECT - Client Access rejects every request from the personal computer to access objects on the AS/400 system. An error message is sent to the PC application. - *OBJAUT - The Client Access programs on the system verify normal object authorities for any object requested by a PC program. For example, if file transfer is requested, authority to copy data from the database file is checked. - *REGFAC - The system uses the system's registration facility to determine which exit program (if any) to run. If no exit program is defined for an exit point and this value is specified, - *OBJAUT is used. Qualified-program- name - The Client Access program calls this user-written exit program to determine if the PC request should be rejected. The exit program is called only if normal authority checking for the object is successful. The Client Access program passes information about the user and the requested function to the exit program. The program returns a code indicating whether the request should be allowed or rejected. If the return code indicates the request should be rejected or if an error occurs, an error message is sent to the personal computer.

User Accounts

CP-125543 Default passwords supplied with software packages should be changed upon installation.

Change all default application and operating system passwords upon installation of applications.

CP-125549 New user accounts that have not changed their passwords from the default should be reviewed

Contact all users that have not changed their password and mandate that they do so to for the protection of their information.